

AI AUDIT REPORT

- Student name: Dương Gia Huy
- Student ID: 23127052

AI-generated Artifact

Ở mỗi Artifact khi AI generate ra, mặc dù trong câu prompt cũng như Agent Skill đã có yêu cầu generate thành bảng format .md, nhưng em đều phải prompt thêm 1 lần nhắc AI xuất kết quả thành bảng dạng **.md**.

Em đã sử dụng AI cho những task sau đây:

Artifact 1:

1. Prompt + Tool

- **Tool:** Gemini 3.1 Pro
- **Timestamp:** 09:14 30/06/2026
- **Prompt:** Yêu cầu áp dụng kỹ thuật Phân tích Miền (Domain Testing) và Phân tích Giá trị biên (BVA) để thiết kế kịch bản kiểm thử (Test Cases) cho tính năng FR-04: Quản lý hồ sơ cá nhân với các ràng buộc cụ thể về dữ liệu, phân quyền và hiển thị.

2. AI Output: Đã tạo thành công 1 bảng phân tích Domain (8 thuộc tính), 1 bảng phân tích BVA (cho độ dài Số điện thoại) và 8 Test Cases chi tiết bao phủ Happy path (SĐT 10-11 số hợp lệ), Edge cases (sai định dạng, BVA Min-1/Max+1) cùng các kịch bản kiểm thử bảo mật (Email read-only, chặn đổi Role, chặn đổi profile người khác).

3. Verdict: INCOMPLETE

4. Reasoning:

- Các test case do AI tạo đã bao phủ hầu hết các domain cần kiểm tra, bao gồm happy path các edge cases và cả về bảo mật tài khoản theo đặc tả nhưng vẫn chưa đạt được coverage 100%, do vẫn còn thiếu test case kiểm tra ràng buộc về loại ký tự của biến số điện thoại (như 098abc1041 hoặc 098-102-512) và kiểm tra dữ liệu rỗng đối với trường SĐT
- AI đã đề xuất một kịch bản kiểm tra bảo mật (thay đổi user id trong request payload để cập nhật hồ sơ tài khoản khác) nhưng test case không khả thi đối với hệ thống hiện tại, do backend thực hiện xác thực user bằng cách giải mã trực tiếp từ token JWT gửi lên qua header.

5. Student Fix: Bổ sung thêm 2 test cases TC_FR04_06: kiểm tra lỗi SĐT chứa ký tự chữ cái hoặc ký tự đặc biệt và TC_FR04_07: Báo lỗi khi bỏ trống SĐT để bao phủ toàn bộ theo đặc tả và loại bỏ (bỏ qua) test case TC_FR04_10: kiểm tra cập nhật chéo tài khoản của AI do kiến trúc dùng JWT. Và tinh chỉnh lại phần test steps của TC_FR04_09: Không thể tự ý thay đổi thuộc tính Role để thực hiện dễ dàng hơn.

Artifact 2:

1. Prompt + Tool

- **Tool:** Gemini 3.1 Pro
- **Timestamp:** 16:08 01/07/2026
- **Prompt:** Yêu cầu thiết kế kịch bản kiểm thử cho tính năng Giỏ hàng (FR-07) bao gồm hiển thị danh sách, thêm/xóa/sửa số lượng sản phẩm, kiểm tra nhãn tổng tiền và trạng thái giỏ hàng trống dựa trên điều kiện context.

2. AI Output: Đã tạo 9 Test Cases bao phủ các luồng xử lý và giao diện bằng việc áp dụng kỹ thuật Phân tích Miền (Domain Testing) để kiểm tra các trạng thái hợp lệ/không hợp lệ và Phân tích Giá trị biên (BVA) cho biến số lượng (Min = 1).

3. Verdict: INCOMPLETE

4. Reasoning:

- Các test case do AI tạo đa phần chỉ tập trung vào giao diện (1 phần là do prompt ràng buộc AI chỉ chú ý tới đặc tả) mà bỏ sót các lỗi kinh điển trong thương mại điện tử (như mất dữ liệu khi refresh trang - F5, thêm vào giỏ hàng với số lượng sản phẩm là số âm từ trang chi tiết sản phẩm). Và thiếu 1 test case (TC_FR07_11: Kiểm tra chức năng của nút "Mua tiếp") do nút "Mua tiếp" không hề được đề cập trong đặc tả nhưng lại có trong giao diện giỏ hàng.
- Bên cạnh đó còn có 1 test case mà AI vi phạm nguyên tắc kiểm thử độc lập (gộp chung thao tác tăng và giảm số lượng vào một kịch bản).

5. Student Fix: Em đã tách ra test case mà AI vi phạm (gộp chung thao tác tăng và giảm số lượng vào một kịch bản) thành 2 test cases riêng biệt TC_FR07_05 và TC_FR07_06, đồng thời bổ sung thêm 3 test cases TC_FR07_11: Kiểm tra chức năng của nút "Mua tiếp", TC_FR07_12: Kiểm tra tính nhất quán trạng thái của giỏ hàng, TC_FR07_13: Giao diện và API cho phép người dùng nhập và lưu số lượng sản phẩm là số âm để đảm bảo bao phủ đầy đủ và tinh chỉnh lại test steps cho các test cases cho chi tiết hơn.

Artifact 3:

1. Prompt + Tool

- **Tool:** Gemini 3.1 Pro
- **Timestamp:** 13:19 04/07/2026
- **Prompt:** Yêu cầu thiết kế kịch bản kiểm thử cho tính năng FR-15: Product management (CRUD) với các ràng buộc về Tên, Giá và Danh mục sản phẩm theo đúng 4 bước quy trình.

2. AI Output: Tạo thành công 9 Test Cases bao phủ các luồng Create, Read, Update, Delete (bao gồm cả Happy path và Edge cases) sử dụng kỹ thuật Kiểm thử Miền (Domain Analysis) và Phân tích Giá trị biên (BVA).

3. Verdict: INCOMPLETE

4. Reasoning:

- Các test case do của AI nhìn chung có nền tảng tốt nhưng chưa hoàn thiện do tiếp cận quá thiên về lý thuyết và phụ thuộc gần như hoàn toàn vào văn bản đặc tả gốc. AI tập trung mạnh vào luồng dữ liệu cốt lõi nhưng bỏ sót các test case về mặt khả dụng của giao diện (ví dụ như chưa kiểm tra sự tồn tại của nút "Xem chi tiết").

- Nhưng cũng do tuân thủ nguyên tắc không suy diễn ngoài đặc tả trong câu prompt agent skill, AI cũng bỏ qua các trường dữ liệu như "URL ảnh" - vốn tồn tại trong source code và chỉ đưa ra các bước thao tác, tên nút bấm chỉ mang tính chung chung.

5. Student Fix: Em đã tái cấu trúc lại các test case bằng cách tách riêng các test case của trường Giá thêm hai nhóm độc lập (trường hợp số âm **TC_FR15_06** và trường hợp bỏ trống **TC_FR15_07**) nhằm tăng độ bao phủ, đồng thời bổ sung các test case về giao diện như **TC_FR15_10: Kiểm tra hiển thị nút có chức năng Xem chi tiết**, logic hiển thị ảnh thay thế (placeholder) khi URL ảnh trống **TC_FR15_12: Hiển thị hình placeholder khi để trống mục URL ảnh** và cũng như là kiểm tra hệ thống phải báo lỗi/ngăn chặn nếu nhập ký tự không phải số vào Giá sản phẩm **TC_FR15_08: Báo lỗi/ngăn chặn khi nhập ký tự không phải số vào Giá sản phẩm**. Cuối cùng, toàn bộ các test steps được bổ sung thêm phần nhập URL ảnh, cũng như các Pre-conditions (Ví dụ thao tác xóa danh mục) và nhấn hiển thị được chuẩn hóa lại (đổi thành "Lưu sản phẩm") để khớp hoàn toàn với thiết kế giao diện thực tế.

Artifact 4:

1. Prompt + Tool

- Tool:** Gemini 3.1 Pro
- Timestamp:**
- Prompt:** Thiết kế kịch bản kiểm thử (test cases) bằng Kiểm thử Miền (Domain Testing) và Phân tích Giá trị biên (BVA) cho tính năng FR-20: Quản lý hồ sơ cá nhân. Hệ thống gồm các ràng buộc về số ĐT (bắt đầu bằng 0, 10-11 số), các trường read-only (Email) và các hạn chế quyền qua API (ngăn chặn sửa đổi 'role' và IDOR) dựa trên môi trường Mobile/Proxy.

2. AI Output: Đã thiết lập 1 bảng phân tích Domain với 9 vùng dữ liệu, 1 bảng BVA chi tiết cho độ dài số điện thoại (từ Min-1 tới Max+1) và trích xuất 10 Test Cases chi tiết bao phủ UI Happy Path, Invalid UI validation, UX của Mobile keyboard và đặc biệt là 3 cases bảo mật API chặn đứng tấn công qua Proxy.

3. Verdict: INCOMPLETE

4. Reasoning:

- AI đã xác định đúng các điểm cốt lõi của FR-20 như trạng thái đăng nhập, quyền sở hữu hồ sơ, số điện thoại bắt đầu bằng 0, độ dài 10-11 chữ số, Email read-only và kiểm tra **role** qua API/Proxy.
- Tuy nhiên, bộ test vẫn chưa bao phủ hết các miền không hợp lệ của số điện thoại. AI vẫn thiên về BVA theo độ dài nên bỏ sót các lớp invalid khác của số điện thoại như chữ cái, khoảng trắng, ký tự đặc biệt và trường hợp rỗng.
- Kịch bản IDOR sửa **UserID/ProfileID** cũng không phù hợp với hệ thống thật vì backend xác thực bằng JWT, không tin vào định danh do client truyền lên.

5. Student Fix:

- Em đã tinh chỉnh lại bộ test cho FR-20 để bám sát hơn vào bản chất của hệ thống và giao diện thực tế, cụ thể là giữ lại các case BVA cho số điện thoại 10, 11, 9 và 12 chữ số, thêm case kiểm tra **TC_FR20_05: Layout không bị vỡ sau khi thành công thông tin với Họ tên bằng chuỗi 255 ký tự**, **TC_FR20_09: Kiểm tra dữ liệu Địa chỉ giao hàng mặc định được lưu sau khi đăng xuất và đăng nhập lại**. Đồng thời, em chuẩn hóa lại tên nút và bước thao tác theo giao diện thực tế, chuyển thống nhất sang hành động "Cập nhật" và điều chỉnh mô tả expected result cho rõ ràng hơn.

- Hơn nữa, em loại bỏ kịch bản IDOR/cập nhật chéo tài khoản vì không khả thi với kiến trúc xác thực JWT của hệ thống. Cũng như là bộ test này đã trùng với 1 test case ở FR-04 **TC_FR04_09: Không thể tự ý thay đổi thuộc tính Role**, vì frontend web và mobile đều dùng chung backend, nên nếu dùng Postman để test thêm lần nữa là không có ý nghĩa.

Đánh giá & Kết luận

Đánh giá độ chính xác của AI

- VALID: 0/4 (0%)** ()
- INCOMPLETE: 4/4 (100%)** (*Artifact 1, Artifact 2, Artifact 3, Artifact 4*).
- INVALID: 0/4 (0%)** ()

Kết luận

Thông qua quá trình thực hiện bài tập và đối chiếu kết quả, em rút ra kết luận về việc ứng dụng AI như sau:

Khi nào nên dùng AI:

- Khi cần tạo nhanh bộ khung test case ban đầu, bảng Domain/BVA hoặc danh sách các hướng kiểm thử cơ bản.
- Khi cần gợi ý thêm các edge cases phổ biến để tránh bỏ sót ở bước đầu.
- Khi cần hỗ trợ diễn đạt lại test steps, chuẩn hóa cách trình bày, hoặc hệ thống hóa nội dung báo cáo.

Khi nào không nên dùng AI:

- Khi cần bộ test hoàn chỉnh và chính xác tuyệt đối theo đặc tả, vì AI vẫn có thể bỏ sót các miền hoặc BVA quan trọng.
- Khi kiểm thử phụ thuộc vào kiến trúc triển khai thực tế như JWT, quyền truy cập, hoặc luồng API không thể suy diễn chỉ từ prompt.
- Khi giao diện và source code có khác biệt với mô tả nghiệp vụ, vì AI dễ tạo test steps chung chung hoặc dựa quá nhiều vào giả định.